

LB 1

Projektarbeit OWASP Top Ten Project

Rahmenbedingungen

Das *Open Web Application Security Project* (OWASP) ist eine weltweite Non-Profit Organisation die sich zum Ziel setzt, Qualität und Sicherheit von Software zu verbessern. Es ist das Ziel, Entwickler, Designer, Softwarearchitekten für potentielle Schwachstellen zu sensibilisieren und aufzuzeigen, wie sich diese vermeiden lassen. Die folgenden „OWASP Top Ten“ stellen unter Web-Sicherheitsexperten einen anerkannten Konsens dar, was die derzeit kritischen Lücken in Web-Anwendungen betrifft (Stand 2025):

Top 10: 2025 List

1. [A01:2025 - Broken Access Control](#)
2. [A02:2025 - Security Misconfiguration](#)
3. [A03:2025 - Software Supply Chain Failures](#)
4. [A04:2025 - Cryptographic Failures](#)
5. [A05:2025 - Injection](#)
6. [A06:2025 - Insecure Design](#)
7. [A07:2025 - Authentication Failures](#)
8. [A08:2025 - Software or Data Integrity Failures](#)
9. [A09:2025 - Security Logging and Alerting Failures](#)
10. [A10:2025 - Mishandling of Exceptional Conditions](#)

Auftrag

1. Wählen Sie OWASP Top 10 Themen aus (Anzahl Gruppenmitglieder = Anzahl zu wählende Themen), die Sie in diesem Auftrag bearbeiten möchten (jedes Thema muss von der Klasse mind. einmal ausgearbeitet werden!)
2. Analysieren Sie die ausgewählten Themen mit Hilfe der OWASP-Seite <https://owasp.org/Top10/> (und allfälligen weiterführenden Quellen / Internetrecherche)
3. Erklären Sie in eigenen Worten, was sich hinter der Abkürzung CWE versteckt und wie CWE mit den OWASP Top 10 zusammenhängen.
4. Beschreiben Sie den Unterschied der OWASP Top 10 Risk und OWASP Proactive Control (<https://owasp.org/www-project-proactive-controls/>)
5. Die ausgewählten Themen werden wie folgt ausgearbeitet:
 - Beschreibung der theoretischen Hintergründe und der Bedrohung sowie mögliche Folgen
 - Schwachstelle mit konkretem Codebeispiel vorstellen und erläutern
 - Massnahme wie die Sicherheitslücke geschlossen werden kann, an einem konkreten Codebeispiel
 - Abgabe von Dokumentation und Code Beispiele via Teams-Aufgabe

Inhalt der Dokumentation

- Überblick
- Erläuterungen zu Aufgabe 3 und 4
- Theoretische Hintergründe
- Schwachstelle mit Codebeispiel
- Massnahme mit Codebeispiel
- Resultate, Erkenntnisse
- Hinweise auf weitere Unterlagen, Übungen, Tutorien (inkl. verwendeter Quellen)

Zeitraahmen

Als Vorbereitung stehen 8 Lektionen während der Schule zur Verfügung. Die Vorstellung soll die Problemstellung (Angriffspunkt, Auswirkung, Technologie) und Lösung (Technologie und sinnvolle Gegenmassnahmen) anhand von praktischen Beispielen (Live-Demo der Codebeispiele - keine PowerPoint), aufzeigen. Die Live-Demo darf pro Thema maximal 7 Min. dauern und ist in Standardsprache zu halten.

Resultate

- Vollständiger schriftlicher Theorie Teil mit praktischen Code-Beispielen
- Live-Demo anhand von Beispielen von Sicherheitslücken und geeignete OWASP Gegenmassnahmen

Termine

Tag1: Fr 27.02.2026

Tag2: Fr 06.03.2026

Tag3: Fr 13.03.2026

Tag4: Fr 20.03.2026

Abgabe: Do 26.03.2026, 23:59 h

Präsentationen: Fr 27.03.2026, ab 08:50 h

Bewertung

Siehe Bewertungsraster_OWASP.xlsx